

Guía Metodológica — Encuesta CSCRМ España 2026

Diseño, Aplicación, Análisis e Interpretación de Resultados

Versión 1.0 · Documento (b) del Kit de Encuesta CSCRМ

1. Fundamento Epistemológico y Diseño de la Investigación

1.1. Naturaleza del Estudio

Esta encuesta constituye un **instrumento de investigación mixto** (cuantitativo-cualitativo) orientado a evaluar la madurez de las organizaciones españolas en la Gestión de Riesgos de Ciberseguridad en la Cadena de Suministro (CSCRМ). Su diseño se enmarca en la tradición de los estudios de madurez de capacidades (*Capability Maturity Models*), con referencia directa al marco CMM/CMMI adaptado al ámbito de la ciberseguridad.

El estudio adopta un enfoque **descriptivo-comparativo**: descriptivo porque caracteriza el estado actual de la madurez CSCRМ en las organizaciones participantes; comparativo porque permite establecer benchmarks sectoriales, por tamaño organizativo y por régimen normativo aplicable.

1.2. Marco Teórico y Referencias Fundacionales

El diseño de la encuesta se apoya en los siguientes marcos de referencia primarios:

Marco / Norma	Versión / Fecha	Contribución al diseño
NIST SP 800-161r1	Actualización nov. 2024	Estructura de dominios CSCRМ (Identify, Protect, Detect, Respond, Recover aplicados a SC)
NIST CSF 2.0	Feb. 2024	Subcategorías GV.SC-01 a GV.SC-10 como eje de gobernanza
INCIBE-CERT IMC v2.8	Feb. 2023	46 métricas de ciberresiliencia; escala L0-L5; 8 indicadores nucleares CSCRМ
CCN-CERT / ISMS Forum	Feb. 2025	Cuestionario Unificado de Cadena de Suministro; pirámide de supervisión de 6 niveles
ISO/IEC 27001:2022	Oct. 2022	Cláusulas 5.19–5.23 (seguridad en relaciones con proveedores)
ENISA NIS Investments 2025	Dic. 2025	Benchmarks europeos; indicadores de cumplimiento NIS2
ENISA NIS360	Mar. 2025	Madurez sectorial; sectores en zona de riesgo
ENS RD 311/2022	May. 2022	Marco normativo nacional; controles op.ext, figura POC
Foro Nacional de Ciberseguridad	Sep. 2025	Propuestas nacionales de medidas mínimas CSCRМ
Cipher/Prosegur Supply Chain Report	Feb. 2026	Indicadores cuantitativos de situación: duplicación de ataques, 254 días de detección

1.3. Hipótesis de Investigación

La encuesta está diseñada para contrastar las siguientes hipótesis:

- H1: El nivel de madurez CSCRМ en las organizaciones españolas de sectores esenciales es significativamente inferior al nivel necesario para cumplir con los requisitos del Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad.
- H2: Existe una correlación positiva y significativa entre el tamaño organizativo y el nivel de madurez CSCRМ.
- H3: Las organizaciones del sector financiero presentan mayor madurez CSCRМ que el resto de sectores, dada la mayor presión regulatoria (DORA, requisitos del Banco de España / BCE).
- H4: Menos del 30% de las organizaciones encuestadas dispone de un proceso formal de gestión del ciclo de vida completo del proveedor (selección → onboarding → monitorización → offboarding).
- H5: El SBOM y el análisis de riesgo n-tier son los indicadores con menor tasa de implementación.

2. Población Objetivo y Estrategia de Muestreo

2.1. Población Objetivo

La población objetivo del estudio está constituida por las **organizaciones con sede o actividad principal en España** que pertenezcan a alguno de los sectores definidos como esenciales o importantes por la Directiva NIS2 y el Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad:

Sectores de alta criticidad (Anexo I NIS2):

- Energía (electricidad, gas, petróleo, hidrógeno, calefacción/refrigeración urbana)
- Transporte (aéreo, ferroviario, marítimo, por carretera)
- Banca y entidades de crédito
- Infraestructuras de mercados financieros
- Sector sanitario
- Agua potable
- Aguas residuales
- Infraestructura digital
- Gestión de servicios TIC (B2B)
- Espacio
- Administración pública

Sectores importantes (Anexo II NIS2):

- Servicios postales y mensajería
- Gestión de residuos
- Fabricación, producción y distribución de sustancias y mezclas químicas
- Producción, transformación y distribución de alimentos
- Fabricación (dispositivos médicos, productos informáticos, equipos eléctricos, vehículos)
- Proveedores de servicios digitales
- Investigación

2.2. Unidad de Análisis

La unidad de análisis es la **organización**, representada por un único encuestado con perfil directivo en materia de ciberseguridad (CISO, CSO, CIO, DPO, Director de Riesgos o equivalente). En organizaciones sin un rol específico de ciberseguridad, el encuestado puede ser el Director de TI o el responsable designado para el cumplimiento NIS2.

2.3. Estrategia de Muestreo

Se propone un diseño de **muestreo estratificado por sector y tamaño organizativo**, con los siguientes parámetros:

Parámetro	Valor
Tamaño muestral mínimo (estudio sectorial representativo)	n = 385 (margen de error $\pm 5\%$, nivel de confianza 95%)
Tamaño muestral recomendado	n = 600 (para análisis por sectores con subgrupos)
Estratificación primaria	Sector de actividad (11 sectores esenciales + 7 importantes)
Estratificación secundaria	Tamaño organizativo (micro, pequeña, mediana, grande, corporación)
Cuota mínima por estrato	n = 15 por celda sector $\times$ tamaño

2.4. Métodos de Distribución

- Canal primario: Distribución digital mediante plataforma de encuestas segura (LimeSurvey autohospedado o Microsoft Forms con cifrado en tránsito y en reposo)
- Canales de difusión: CCN-CERT, INCIBE, Foro Nacional de Ciberseguridad, ISMS Forum Spain, CCI (Centro de Ciberseguridad Industrial), asociaciones sectoriales (SEOPAN, UNESA, AEB, Farmaindustria, SEIS)
- Canal complementario: Entrevistas semiestructuradas con una submuestra de n = 30 encuestados de alta representatividad para triangulación cualitativa

3. Estructura de la Encuesta y Descripción de Bloques

La encuesta se organiza en **12 bloques temáticos** con un total de **55 preguntas principales**:

Bloque	Temática	N.º Preguntas	Tipo predominante
0	Perfil organizativo	6	Selección única / múltiple
I	Gobernanza y programa CSCRm	8	Escala Likert L0-L5 + selección
II	Inventario, clasificación y due diligence	8	Escala Likert L0-L5 + selección
III	Requisitos contractuales	6	Escala Likert L0-L5
IV	Supervisión continua y monitorización	7	Escala Likert + cuantitativo
V	Respuesta a incidentes con terceros	4	Escala Likert L0-L5
VI	Continuidad de negocio y resiliencia	3	Escala Likert L0-L5
VII	SBOM, PQC e IA en cadena de suministro	8	Selección + escala
VIII	Zero Trust y acceso de proveedores	5	Escala Likert L0-L5
IX	Ecosistemas de intercambio de información	4	Selección única/múltiple
X	Cumplimiento, auditoría y ciclo de vida	5	Escala Likert + selección múltiple
XI	Madurez global, inversión y prioridades	6	Mixto (escala, selección, texto libre)

4. Sistema de Puntuación e Índice de Gestión de Madurez (IGM)

4.1. Principios de Puntuación

Las preguntas con escala de madurez L0-L5 se puntúan directamente con valores de 0 a 5. Las preguntas de selección única se convierten a escala 0-5 según la tabla de conversión incluida en la Plantilla Excel (Documento e). Las preguntas de selección múltiple generan subíndices por dimensión.

4.2. Cálculo del IGM

El **Índice de Gestión de Madurez (IGM)** se calcula como la media ponderada de los cinco dominios funcionales:

$$IGM = \sum (Puntuación_dominio_i \times Peso_dominio_i) / \sum Peso_dominio_i$$

Dominio	Peso	Justificación
Gobernanza y Programa (Bloques 0, I)	20%	Base estructural sin la cual el resto es cosmético
Identificación y Evaluación (Bloque II)	20%	No se puede gestionar lo que no se conoce
Protección y Controles Técnicos (Bloques III, VII, VIII)	25%	Mayor impacto directo en la reducción de superficie de ataque
Detección y Supervisión (Bloque IV)	20%	Crítico dado el indicador de 254 días de detección media
Respuesta, Recuperación y Resiliencia (Bloques V, VI, IX)	15%	Esencial pero dependiente de los dominios anteriores

4.3. Interpretación del IGM

Rango IGM	Nivel de Madurez	Interpretación	Acción Recomendada
0,0 – 1,0	Crítico	Programa CSCRМ inexistente o puramente nominal	Plan de emergencia: gobernanza básica inmediata
1,1 – 2,0	Inicial	Prácticas aisladas sin coherencia sistémica	Establecer inventario, política y responsable en 90 días
2,1 – 3,0	En desarrollo	Procesos definidos con brechas relevantes	Completar contratos, monitorización y respuesta a incidentes
3,1 – 4,0	Avanzado	Programa estructurado con métricas	Integrar SBOM, PQC, Zero Trust y evaluaciones n-tier
4,1 – 5,0	Optimizando	Mejora continua sistematizada	Liderar iniciativas sectoriales; contribuir a ISACs; preparar PQC

4.4. Subíndices por Dominio

Además del IGM agregado, se calculan cinco **subíndices de dominio** (IGM-G, IGM-I, IGM-P, IGM-D, IGM-R) y tres **subíndices de tendencias emergentes** (IGM-SBOM, IGM-PQC, IGM-IA), que permiten identificar fortalezas y brechas específicas.

5. Validez, Fiabilidad y Consideraciones Éticas

5.1. Validez de Contenido

La validez de contenido se garantiza mediante:

- Correspondencia explícita de cada pregunta con al menos un indicador del marco IMC de INCIBE-CERT, una subcategoría del NIST CSF 2.0 (GV.SC) o un control del ENS RD 311/2022 (véase Documento d — Mapeo Normativo).

- Revisión por un panel de expertos (CISO de al menos tres sectores distintos, un académico en ciberseguridad y un representante del CCN-CERT o INCIBE) antes de la distribución definitiva.

5.2. Fiabilidad

- Consistencia interna: coeficiente Alpha de Cronbach esperado > 0,80 para la escala global.
- Test-retest: se recomienda repetir la encuesta con una submuestra de $n = 20$ organizaciones con un intervalo de 30 días para verificar la estabilidad temporal.
- Triangulación: contraste de los resultados cuantitativos con las entrevistas semiestructuradas de la submuestra cualitativa.

5.3. Consideraciones Éticas

- Anonimización: las respuestas serán tratadas de forma agregada; ningún informe publicado identificará organizaciones individuales sin consentimiento expreso.
- Consentimiento informado: el formulario incluirá una cláusula de consentimiento informado alineada con el RGPD (Reglamento UE 2016/679) antes del inicio de la encuesta.
- Minimización de datos: solo se recabarán los datos estrictamente necesarios para los objetivos de investigación.
- Acceso a resultados: todas las organizaciones participantes recibirán su informe individual de posicionamiento relativo al benchmark sectorial.

6. Análisis de Datos

6.1. Análisis Cuantitativo

- Estadística descriptiva: media, mediana, moda, desviación típica y percentiles (P25, P50, P75) para cada indicador y para el IGM global.
- Análisis de componentes principales (ACP): para identificar los factores latentes subyacentes a la madurez CSCRМ.
- Análisis de conglomerados (cluster analysis): para identificar perfiles tipológicos de organizaciones según su postura CSCRМ.
- Correlaciones de Spearman: para variables ordinales (escala L0-L5) y análisis de la relación entre madurez CSCRМ y variables organizativas (tamaño, sector, presupuesto).
- Tests de Mann-Whitney / Kruskal-Wallis: para comparaciones entre grupos (sectores, tamaños) cuando no se cumplen los supuestos de normalidad.

6.2. Análisis Cualitativo

- Análisis de contenido temático: de las respuestas al campo abierto P11.6, utilizando codificación inductiva con apoyo de herramientas de análisis de texto.
- Análisis de frecuencias textuales: identificación de términos y conceptos recurrentes en las respuestas abiertas.

6.3. Herramientas de Análisis

- Análisis cuantitativo: Microsoft Excel (Plantilla IGM — Documento e) + R o SPSS para análisis avanzado.
- Visualización: Power BI o Tableau para dashboards ejecutivos.
- Análisis cualitativo: ATLAS.ti o NVivo para análisis de texto.

7. Calendario de Ejecución Propuesto

Fase	Actividad	Duración estimada
1	Revisión por panel de expertos y piloto (n=10)	3 semanas
2	Distribución y recogida de respuestas	6–8 semanas
3	Depuración y validación de datos	1 semana
4	Análisis cuantitativo y cualitativo	3 semanas
5	Elaboración de informes (sectorial + individual)	2 semanas
6	Difusión de resultados (informe público agregado)	1 semana
Total		~4 meses

8. Limitaciones Conocidas del Estudio

- Sesgo de deseabilidad social: los encuestados pueden tender a sobrestimar su nivel de madurez. Se mitiga mediante preguntas de contraste (p. ej., P4.7 sobre tiempo real de detección) y la triangulación cualitativa.
- Sesgo de selección: las organizaciones con mayor madurez CSCRМ pueden estar sobrerrepresentadas, al ser más propensas a participar en estudios de este tipo.
- Temporalidad: el panorama normativo español está en transición activa (NIS2 en transposición); los resultados deben interpretarse en el contexto regulatorio de abril de 2026.
- Autoevaluación: la encuesta se basa en la percepción del encuestado, no en evidencia auditada. Los resultados son indicativos, no certificatorios.

© 2026 · Guía Metodológica CSCRМ España · Documento (b) del Kit de Encuesta

Referencia: INCIBE-CERT IMC v2.8 · NIST SP 800-161r1 · ENS RD 311/2022 · ENISA NIS360 2025